

Kryptographie und Embedded-Security

IoT Workshop

Fredy Hirt - 02.09.2026

Previously on

- Ihr versteht die grundlegenden Unterschiede zwischen Authentifizierung und Autorisierung
- Ihr kennt die Mechanismen zur Authentifizierung und Autorisierung in MQTT
- Ihr unterscheidet zwischen physischer und logischer Topic-Modellierung

Agenda

- Repetition Authentifizierung & Autorisierung (15')
- Input Kryptographie (40')
- Input Embedded-Security (35')
- Arbeit am Projekt (90')

Ziele

- Ihr versteht die grundlegende Funktionsweise von
 - symmetrischer Kryptographie
 - asymmetrischer Kryptographie
- Ihr kennt die grundlegenden Herausforderungen an Security auf Embedded-Systems

Motivation

- Wer hat einen Staubsaugroboter?

Motivation

👉 Lies den Artikel [The DJI Romo robovac had security so poor, this man remotely accessed thousands of them](#) durch

Symmetrische Kryptographie

- Ein gemeinsamer geheimer Key
- Sender und Empfänger kennen denselben Key

Eigenschaften

- ✓ Einfach zu implementieren
- ✓ Schnell

Eigenschaften

- ✗ Schlüssel muss sicher verteilt werden
- ✗ Ein kompromittierter Key kompromittiert alles

Typische symmetrische Algorithmen

- AES-128
- AES-256
- ChaCha20

Asymmetrische Kryptographie

- Zwei Schlüssel:
 - **Public Key** 
 - **Private Key** 
- Was mit dem einen verschlüsselt wird, kann nur mit dem anderen entschlüsselt werden

Eigenschaften

- ✓ Kein Shared Secret nötig

Eigenschaften

- ✗ Komplex
- ✗ Rechenintensiv

Typische asymmetrische Algorithmen

- RSA
- ECDSA (Signaturen)
- ECDHE (Key Exchange)

Kryptographie in MQTT

☞ MQTT selbst enthält keine Kryptographie
Security wird durch **TLS** bereitgestellt.

MQTT + TLS = MQTTS

Was macht TLS?

- TLS kombiniert:
 - Asymmetrische Kryptographie
 - Symmetrische Kryptographie

Warum Kombination?

- Asymmetrisch:
 - Authentifizierung
 - Session-Key aushandeln
- Symmetrisch:
 - Schnelle Datenübertragung

PKI – Chain of Trust

Problem:

Woher weiss der Client, dass der Broker echt ist?

Lösung

Zertifikate enthalten:

- **Public Key**
- Identität
- Signatur einer **CA** (Certificate Authority)

Lösung (Chain of Trust)

Root CA



Intermediate CA



Server-Zertifikat

👉 Wenn Root vertraut wird, wird der gesamten Kette vertraut.

Embedded-Security

- Geräte sind physisch zugänglich
- Flash kann ausgelesen werden
- Firmware kann manipuliert werden
- Keys können extrahiert werden
- Side-Channel-Angriffe
- Fault Injection
- Debug-Interfaces (JTAG)

Secure Boot

Bootloader prüft:

- Ist die Firmware digital signiert?
 - Ja → Start
 - Nein → Stop
- Schützt vor manipulierten Images

Firmware Signing

- Hersteller:
 - Signiert Firmware mit **private Key**
- Gerät:
 - Prüft Signatur mit **public Key**

OTA Updates

Over-The-Air Updates müssen:

- Verschlüsselt übertragen werden
- Signiert sein
- Versioniert sein
- Rollback-Schutz besitzen

Weiterführendes

- IoT Security Breaches: 4 Real-World Examples
- Sicherheitslücke im LTE-Netz